

Mike Adams - Zack Vorhies

source: <https://youtu.be/6nu4eX1wsNM>

-- begin section --

[Mike Adams]

Brighteon.com, interview at Mike Adams. And today we are joined by the Google whistleblower, Zach Voorhees, in the aftermath of the CrowdStrike Falcon security failure that bricked, I think, maybe millions of Windows server systems all over the world with repeating endless loop blue screen of death boot failure. So welcome, Zach.

Quite an interesting time to be talking about all this, isn't it? Yes, it is.

[Zach Vorhies]

CrowdStrike's update was rolled out to millions of computers, and it caused a blue screen of death because it was causing a crash in a privileged piece of code called a system driver. And this system driver, when it crashes, it doesn't just terminate, it actually halts the operating system because it doesn't know what to do anymore, because you cannot have a crash in privileged code. You can have a crash in unprivileged code in which the application terminates.

But that's not what's going on here.

[Mike Adams]

Right. I saw there was a post that took a look at that file. I don't know if you've seen this or if I'm wrong.

Correct me. But I thought it showed that at least part of this file was just a bunch of zeros, like literally filled with the digit zero over and over again.

[Zach Vorhies]

Did you see that? I did. And I looked at the Hacker News Forum and some system administrators came in and said that that's not always the case, that all the computers that they have been working with, it is not filled with zeros.

So that was pointed to as the culprit at the beginning. But it looks like that's not always the case.

[Mike Adams]

OK, so let's let's talk about the technical side of this and rolling out. I mean, you're you're an accomplished developer. So you you know that there's always a staging test area.

But this and there's always, you know, the new code is always tested against a wide variety of different operating system variants or installs or hardware systems. Can you talk to us about what what would be typical in a company like this responsible for security? What kind of normal free rollout QC would they have gone through?

[Zach Vorhies]

Yeah, so the normal way that C++ code bases are checked is that they've got a set of automated tools. It looks like those automated tools were not run on this code base for whatever reason, probably because it's old and there's a lot of it was kind of before a lot of these modern tool sets came in. So first off, they're not running a lot of the automated tool sets.

That's my speculation. But more than that. They're rolling it out to everyone at the same time.

Well, and that's not the way that you do a rollout, because what you have to assume is that, well, we all know that code has a lot of bugs in it. It's just it's just the way software is. And so rather than try to make sure you do all the possible checks and roll it out to everyone, what you do is you do a staged rollout where you roll it out to, like, let's say a region.

And then if you wait like an hour, you wait like maybe four hours. If no one starts complaining, then you roll it out to a larger area and you just roll it out. That way, if there is a fatal problem.

You are going to get wind of it really quickly. Yeah. And if they had done that in this case, what they would have done is got a call from a bunch of angry system administrators that just said, you just took down every single one of our computers with this software update.

Right. And instead of doing that, they just roll it out to everyone. And so I hit with this.

[Mike Adams]

So my question is, does it seem? And I understand this is just going to be an educated guess. But does it seem like they bypassed or maybe a rogue deployment person or developer bypassed the normal operating procedure?

There should be a sequence of steps that they go through before they roll out a new patch. Does it seem like they bypass that?

[Zach Vorhies]

Yeah, I think it was somebody trying to go on vacation and they were rolling this out on a Friday. It's pretty famous that **you don't release software on a Friday right before you go home for a weekend**. Absolutely.

You start rolling it out on Monday for this very reason. And it looks like this person rolled it out. It looks like it might have actually bypassed Windows updates because no one got any notification.

They didn't get the consent to opt out. They just got it pushed to them. And the problem with this is that CrowdStrike's software is sort of an anti-malware, anti-virus, anti-penetration software.

And so what it does is **it penetrates other applications and injects code into their executable so that it can monitor bad, malicious behavior and catch it really quickly**. So it's got this privileged access that needs to do. And so this update rollout just simply swapped out the previously working code for a new system driver.

And that system driver crashed the operating system.

[Mike Adams]

So would I be wrong to describe this? This push of this CrowdStrike system file update as itself malware. I mean, this took down systems, which is what it's supposed to prevent from happening, but it did a very effective job.

In fact, I don't think there's ever been a piece of malware that's ever been as effective as this at taking down as many systems all at once, has there?

[Zach Vorhies]

No, not since the viruses in the 90s used to do something similar, but now it's bad software updates by reputable companies that are taking down large sections of the Internet.

[Mike Adams]

Can you think of any other failure in history that had as big of an impact on the world as this?

[Zach Vorhies]

No, no, this is the biggest one to date. I mean, there's there's been other, you know, security vulnerabilities that have happened, but nothing that's taken down so many computers. I mean, it's almost like an attack from Russia or

China to take down infrastructure like that's the scale of this oopsie.

[Mike Adams]

Now, OK, so you use the word oopsie. How do we know it wasn't something on purpose by somebody within CrowdStrike? And I'm not saying that the CrowdStrike company intended to do this, but **perhaps a rogue operator took a payment**, you know, hey, here's 50 Bitcoin.

Push this thing and they did it. Is there any way to exclude that as a possibility?

[Zach Vorhies]

I can't exclude it. I mean, that is definitely possible that they did this in order to sort of weaken our infrastructure and, you know, we get Microsoft, one of the leading computer companies in the world. OK, you know, until until we see that this is not programmer error.

I mean, here's the problem. **It's C++. It's an old code base.**

This sort of problem is endemic with these old code bases. The newer version of C++ has a lot of fixes that prevents this sort of.

-- end section --